



Air University
(Final-Term Examination: Fall 2025)

Subject: **Information Assurance**
Course Code: **CY-103**
Class: **BS-CYS**
Semester: **III**
Section: **A**

Total Marks: **100**
Date:
Time:
Duration: **3 Hours**
FM Name: **Ms. Hina Batool**

HoD Signatures: _____

FM Signatures: _____

Note:

- The answers must be according to the given scenario.
- Understanding question is part of exam.
- Return the paper along with the answer sheet

		(CLO 2)	Marks																			
Q.1	An organization is developing a risk monitoring dashboard to provide senior management with timely insights into its security posture. The risk team has identified numerous potential indicators, but not all reflect meaningful changes in risk. Some indicators are general, while others are highly relevant to the organization's specific risk profile and have a high probability of signalling a shift in risk.		20																			
	As the information security manager, explain how you would select and prioritize risk indicators for the dashboard to ensure they provide meaningful, enterprise-specific insights and effectively signal changes in risk																					
		(CLO 2)	Marks																			
Q.2	i. A risk has the following calculated values (SLE = \$18,500, ARO = 5). What is the maximum amount that should be spent to fully mitigate the costs of this risk? Calculate and discuss.		5+5+ 10=20																			
	ii. If the risk has the following measures (Asset Value = 50\$, Probability =10%, ARO=100) and the mitigation cost is \$100 per year, are you getting any return on the investment you are doing to protect the asset? If yes, how much? Discuss																					
	iii. Complete the following Table																					
	<table><tr><th>Asset</th><th>Risk</th><th>Asset Value</th><th>Exposure Factor</th><th>SLE</th><th>Annualized Frequency</th><th>ALE</th></tr><tr><td>Customer Database</td><td>Hacked</td><td></td><td>.74</td><td></td><td>.25</td><td>\$80,000</td></tr><tr><td>Word Documents and Data Files</td><td>Virus</td><td>\$9,450</td><td></td><td>\$1,650</td><td>.9</td><td></td></tr></table>			Asset	Risk	Asset Value	Exposure Factor	SLE	Annualized Frequency	ALE	Customer Database	Hacked		.74		.25	\$80,000	Word Documents and Data Files	Virus	\$9,450		\$1,650
Asset	Risk	Asset Value	Exposure Factor	SLE	Annualized Frequency	ALE																
Customer Database	Hacked		.74		.25	\$80,000																
Word Documents and Data Files	Virus	\$9,450		\$1,650	.9																	

	(CLO 2)	Marks
Q.3	An organization has identified a cybersecurity risk related to <u>unauthorized access</u> to a critical business system. The risk assessment shows that the <u>risk exceeds</u> the <u>organization's defined risk appetite and tolerance levels</u>. Management is uncertain whether the risk should be accepted, mitigated, transferred, or avoided, considering factors such as <u>duration of the risk</u>, <u>potential business value</u>, <u>cost of controls</u>, and <u>likelihood of occurrence</u>. As the information security manager, explain how you would use a structured risk response workflow to determine the most appropriate risk treatment option for this risk, considering risk appetite, risk tolerance, time persistence, cost-benefit analysis, and likelihood of occurrence.	20
	(CLO 3)	Marks
Q.4	A financial services company recently launched a new digital platform. During a review, it was observed that while <u>senior management is accountable</u> for overall risk, <u>operational teams</u> often make <u>control-related decisions</u> without consulting the <u>risk owners</u>, leading to <u>duplicated efforts</u>, <u>gaps in mitigation</u>, and <u>confusion over accountability</u>. Additionally, some risks are being ignored because no clear owner has been assigned, and controls are implemented inconsistently across departments. As the information security manager, describe how you would establish an effective framework for both <u>risk and control ownership</u> to ensure clear accountability, prevent gaps or overlaps in mitigation, and align security activities with business objectives.	20
	(CLO 2)	Marks
Q.5	A large organization is revising its enterprise risk assessment approach after realizing that <u>many identified risks do not clearly relate</u> to its <u>strategic business objectives</u>. Some teams focus only on <u>technical vulnerabilities</u>, while senior management is concerned that <u>major business-impacting risks may be overlooked</u>. The organization wants a structured method that connects business goals with relevant risk scenarios while also ensuring that generic and technical risks are not ignored. As the information security manager, explain how a combined top-down and bottom-up approach to risk scenario identification can be used to ensure that security risks are aligned with business objectives while maintaining comprehensive risk coverage.	20